

Compliance, Risk, and Governance

Governance Scope

The Award Nomination App handles employee identity, recognition decisions, monetary award data, fraud/integrity signals, payroll integration data, and administrative audit trails. This makes governance important even before formal compliance certification.

Data Classification

Data type	Classification
Tenant config and branding	Internal/customer configuration.
User profile and manager hierarchy	Personal data.
Nomination descriptions	Personal data and potentially sensitive free text.
Award amount and payout status	Financial/compensation-related data.
Payroll profile and pay entries	Highly sensitive payroll data.
Fraud scores and HRBP flags	Sensitive employment decision support data.
Audit logs	Security/audit data.
Model artifacts	Internal intellectual property and governance artifact.
Secrets and tokens	Restricted secrets.

Risk Register

Risk	Impact	Mitigation
Cross-tenant data exposure	High	Tenant auth mapping, tenant-scoped queries, domain checks; add DB RLS for defense in depth.
Admin impersonation misuse	High	App role restriction, audit logs, same-tenant limit; add reason capture and alerting.
False positive fraud flag	Medium	HRBP review, explanations, labels, threshold tuning.
False negative fraud miss	Medium	Weekly graph analytics, retraining, audit review, model monitoring.
Payroll provider failure	High	Broker status, failure events, support notifications, manual reconciliation runbook.
Secret leakage	High	Key Vault, managed identity, avoid logging secrets, rotate credentials.
Model drift	Medium	Monitor score distributions, HRBP label trends, retrain schedule, metrics.
PII in nomination text	Medium	Access controls, retention policy, redaction guidance, privacy notice.
Service Bus duplicate delivery	Medium	<code>ProcessedEvents</code> idempotency.
Analytics agent SQL misuse	High	Tenant-scoped agent tools, query allowlisting/review, output controls.

Auditability

Current audit evidence includes:

- Nomination lifecycle status and timestamps.
- Approver IDs.
- Rejection reason and actor.
- Payment references and payout status.
- Fraud score records.
- HRBP fraud flags and feature summaries.
- Graph findings and run IDs.
- Processed event message IDs, event types, results, and timestamps.
- Admin impersonation logs.
- AI conversation history and export metadata.

Recommended additions:

- Central privileged action audit table.
- Payroll lookup audit.
- Tenant configuration change audit.
- Role assignment/revocation audit.
- Model artifact metadata and checksum table.

Privacy Considerations

The product should have a tenant-facing privacy statement covering:

- What employee data is processed.
- What nomination text may contain.
- How fraud/integrity scoring is used.
- Who can view HRBP flags and analytics.
- Retention period.
- Data subject request process.
- Payroll provider data sharing.
- AI processing boundaries.

AI Governance

AI and ML governance principles:

- Scores are decision-support signals.
- High-risk nominations receive human review.
- Reviewers should see explanations and evidence.
- Tenants should be able to tune thresholds.
- Models should be retrained on tenant-specific data.
- Model releases should be logged.
- Fairness should be reviewed periodically.

Recommended AI governance artifacts:

- Model card per tenant/model version.
- Feature list and intended use.
- Training window and data summary.
- Evaluation metrics.
- Known limitations.
- Human review process.
- Appeal/correction process.
- Drift monitoring dashboard.

Compliance Readiness

The current architecture supports readiness work for:

- SOC 2 Security.
- SOC 2 Availability.
- SOC 2 Confidentiality.
- Enterprise security questionnaires.
- Internal audit.
- Privacy impact assessments.
- AI governance reviews.

Not yet implied:

- Formal SOC 2 certification.
- HIPAA compliance.
- PCI compliance.
- Legal determination of employment decision compliance.

Change Management

Recommended change controls:

- Pull request review for code.
- Migration review for database schema.
- Terraform plan review for infrastructure.
- Separate secret rotation procedures.
- Release notes for tenant-impacting changes.
- Model release review for feature/threshold changes.
- Post-deployment validation through KQL workflows.

Incident Management

Incident categories:

- Authentication outage.
- Data exposure.
- Cross-tenant access issue.
- Payroll submission failure.
- Service Bus backlog or DLQ growth.

- Fraud model unavailable.
- Email notification outage.
- AI analytics incorrect or unsafe output.

Minimum incident process:

1. Detect and triage.
2. Assign severity.
3. Preserve logs and traces.
4. Contain impact.
5. Notify affected tenant(s) when required.
6. Remediate and validate.
7. Post-incident review.
8. Add test or monitor to prevent recurrence.

Business Continuity

Current continuity strengths:

- Primary and secondary backend Container Apps behind Front Door.
- SQL automated backup capability.
- Blob artifact durability.
- Service Bus message TTL and retry/dead-letter behavior.
- Container Apps health probes.

Recommended additions:

- Document RTO/RPO targets.
- Test SQL restore.
- Test failover behavior.
- Export tenant configuration backups.
- Keep previous model artifacts for rollback.